

INFORME EJECUTIVO · INGENIERÍA INVERSA

Portal Empresa

Mapeado Completo

Primera sesión autenticada como empresa en empresas.disjob.com. Descubrimiento del área privada, sistema de chat AJAX, buscador de talento por tags, killer questions y nuevos activos de analítica.

16

PÁGINAS
NUEVAS

9

ENDPOINTS
EMPRESA

2

APIS AJAX

5

LIBS
NUEVAS

3

IDS
ANALYTICS

Fecha de sesión: Miércoles, 10 de junio de 2026

Objetivo: Mapeo del área privada del portal empresa (empresas.disjob.com)

Método: Crawling autenticado con Puppeteer + captura de tráfico HTTP

CONFIDENCIAL · USO INTERNO

La sesión del 10 de junio de 2026 tuvo como objetivo específico el **acceso autenticado al portal de empresas** de DisJob (*empresas.disjob.com*). Por primera vez se logró mapear el área privada completa, incluyendo el dashboard, gestión de posiciones y candidatos, buscador de talento exclusivo y — de forma inesperada — un **sistema de chat AJAX** con pseudo-API JSON, que contradice la arquitectura SSR-pura documentada hasta ahora.

16

PÁGINAS NUEVAS

No presentes en
sesiones anteriores

9

ENDPOINTS
EMPRESA

Área privada
autenticada

2

APIS AJAX / JSON

chatEmp/ — hallazgo
nuevo

3

IDS ANALYTICS

Nuevas propiedades
identificadas

Cronología de la sesión

1

14:08 UTC

Inicio — home.php candidatos

Carga de la home pública de *www.disjob.com*. Confirmación de headers del servidor (nginx/1.10.3, PHP/5.6.38). Inicio de sesión PHPSESSID.

2

14:09 UTC

Navegación al portal empresa

GET a *empresas.disjob.com/* recibe 302 → *empresa_disjob.php*. Nueva cookie PHPSESSID para el dominio empresa. Se detecta HubSpot ID 2442099 y GA G-G51LET61C6 (no documentados previamente).

3

14:11 UTC

Login empresa exitoso

POST a *home_empresa.php* con payload completo documentado. Respuesta 302 → */home_emp.php?nocache=1781100111*. Primera vez que se accede al dashboard autenticado de empresa.

4

14:11 UTC

Descubrimiento del sistema de chat AJAX

Al cargar *home_emp.php* se detectan llamadas fetch a *chatEmp/getNotifications.php* y *chatEmp/getChatList.php* devolviendo respuestas JSON. Primer módulo con API asíncrona confirmado en toda la plataforma.

5

14:13–15:53 UTC

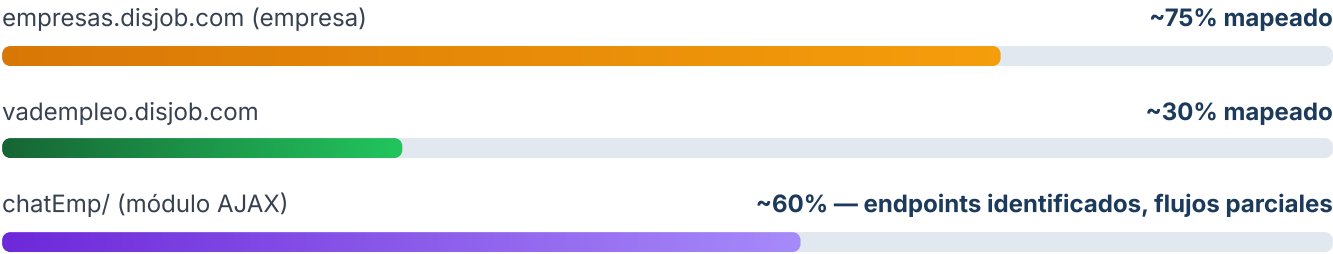
Exploración del área privada empresa

Navegación por: ofertas, gestión de oferta (Asignados/Sin Asignar), candidatos, buscador de talento con búsquedas por tags, perfiles de candidatos, y acceso a killer questions.

Cobertura acumulada por dominio

www.disjob.com (candidatos)

~95% mapeado



Se mapearon por primera vez **16 páginas del área privada de empresa**. El portal tiene una estructura de menú fija con 6 secciones principales, todas accesibles desde el navbar autenticado. Todas las URLs autenticadas incluyen **?nocache=<unix_timestamp>** para anti-caché.

```
empresas.disjob.com/ |— [PÚBLICO] | |— empresa_disjob.php — Login + info empresa | |—
empresa_alta.php — Registro empresa nueva | |— clientes.php ▲ NUEVO | |— precios.php |
|— quienes_somos.php | |— contacta.php | |— politica_privacidad.php ▲ NUEVO | |—
[PRIVADO — requiere PHPSESSID] |— home_emp.php ▲ NUEVO · Dashboard empresa |— ofertas.php
▲ NUEVO · "Tus posiciones" |— ofertas_alta.php ▲ NUEVO · Crear vacante |—
ofertas_modificar.php?i=<ID> ▲ NUEVO · Gestión oferta | |—
accions/killerquestions/alta.php?Id=<N> ▲ NUEVO |— candidatos.php ▲ NUEVO · "Tus
candidatos" |— candidatos_modificar.php?i=<ID> ▲ NUEVO |—
accions/candidats/perfil_candidat.php?Id=<ID> ▲ NUEVO |— colaboradores.php ▲ NUEVO |—
grupos.php ▲ NUEVO |— logos.php ▲ NUEVO · Subempresas |— ficha_empresa.php ▲ NUEVO ·
Datos empresa |— cercadorCandidats/candidatos.php ▲ NUEVO · Buscador Talento |—
chatEmp/getNotifications.php ← AJAX JSON |— chatEmp/getChatList.php ← AJAX JSON
```

Páginas nuevas por categoría

Categoría	URL / Endpoint	Título	Estado
Dashboard	home_emp.php	Dashboard empresa	NUEVO
Posiciones	ofertas.php	Tus posiciones	NUEVO
Posiciones	ofertas_alta.php	Quiero publicar mi vacante	NUEVO
Posiciones	ofertas_modificar.php?i=<ID>	Gestión oferta (Sin Asignar / Asignada)	NUEVO
Candidatos	candidatos.php	Tus candidatos (con filtros)	NUEVO
Candidatos	candidatos_modificar.php?i=<ID>	Editar candidato	NUEVO
Candidatos	accions/candidats/perfil_candidat.php	Perfil candidato	NUEVO
Screening	accions/killerquestions/alta.php	Killer Questions	NUEVO
Talento	cercadorCandidats/candidatos.php	Buscador de candidatos	NUEVO
AJAX / Chat	chatEmp/getNotifications.php	Polling notificaciones	NUEVO

Categoría	URL / Endpoint	Título	Estado
AJAX / Chat	chatEmp/getChatList.php	Listado de chats	NUEVO
Empresa	colaboradores.php	Gestión colaboradores	NUEVO
Empresa	grupos.php	Gestión grupos	NUEVO
Empresa	logos.php	Subempresas / Logos	NUEVO
Empresa	ficha_empresa.php	Datos empresa	NUEVO
Público	clientes.php	Cientes de DisJob	NUEVO

3.1 Login Empresa — Payload Completo Confirmado

✓ Payload documentado por primera vez

Se capturó el POST completo de autenticación empresa, confirmando campos no documentados: `formulari=empresa` y `bt_empresas`. Patrón idéntico al login candidato pero con valores distintos.

POST /HOME_EMPRESA.PHP → LOGIN EMPRESA

```
idioma = cast formulari = empresa ← NUEVO, no documentado antes token =
829772f5e5f80ba99b7d92f43bf0234f (CSRF, 32-char hex) Emp_Usu_Acces = <email>
(input[type=email] maxlength=164) Emp_Pwd_Acces = <password> (input[type=password]
maxlength=200) bt_empresas = ← NUEVO, nombre del botón submit ← HTTP 302 Location:
/home_emp.php?nocache=1781100111 ← Set-Cookie: PHPSESSID=<new_id>; path=/
```

3.2 Dashboard Empresa — Estructura

GET /home_emp.php?nocache=<ts>

Dashboard principal del área empresa. Muestra resumen de actividad y accesos rápidos.

Widgets:

- Mis candidatos → /candidatos.php
- Inscritos esta semana → /candidatos.php?lastWeek=1
- Ofertas activas → /ofertas.php
- Buscador de Talento → /cercadorCandidats/
- Botón "Alta oferta" → /ofertas_alta.php

GET /ofertas_modificar.php?i=<ID>

Gestión de una oferta específica. Permite ver y mover candidatos entre estados.

Secciones:

- [H3] Sin Asignar — inscritos sin estado
- [H3] Asignada — candidatos asignados
- Link "Nueva" → acciones/killerquestions/alta.php?Id=0
- Param opcional: &s=1 (modo vista)

GET /candidatos.php

"Tus candidatos" — listado de candidatos de la empresa con filtros.

Params:

- ?lastWeek=1 — inscritos en los últimos 7 días

Por candidato expone:

- Nombre + link a perfil completo
- tel:<número> — teléfono móvil
- mailto:<email> — email directo

GET /acciones/candidats/perfil_candidat.php

Perfil completo de un candidato individual. Accesible desde el listado y el buscador.

Params:

- ?Id=<NUM> — ID numérico del candidato
- &data=<timestamp> — timestamp ISO del acceso

IDs observados: 76848, 82662, 88391, 89688, 90427, 93328, 94244, 101936, 182022, 265673

3.3 Buscador de Talento — Tag-based Search



Módulo exclusivo para empresas

Accesible solo desde el área privada empresa vía `../cercadorCandidats/candidatos.php`. Usa el widget

Tag-it.js

para entrada de tags múltiples. La búsqueda es full-text sobre CVs y perfiles de candidatos de *toda la base de datos* de la plataforma.

GET /CERCADORCANDIDATS/CANDIDATOS.PHP — BÚSQUEDA POR TAGS

Tag único: GET ?**tags[]=informatica&cerca_restrictiva=on** # Multi-tag (AND lógico): GET ? **tags[]=cordoba&tags[]=cesar&cerca_restrictiva=on** # Resultado: links a perfiles de candidatos → `accions/candidats/perfil_candidat.php?Id=76848&data=<ts>` → `accions/candidats/perfil_candidat.php?Id=82662&data=<ts>` → ... (N resultados, texto del link = ID numérico)

Búsquedas realizadas durante la sesión y resultados observados:

Query ejecutado	Tags	cerca_restrictiva	Resultados
<code>tags[]=inge</code>	1	on	Sin resultados visibles
<code>tags[]=cés</code>	1	on	Sin resultados visibles
<code>tags[]=cordoba</code>	1	on	Sin resultados visibles
<code>tags[]=cordoba & tags[]=cesar</code>	2	on	10 candidatos (IDs: 76848–265673)
<code>tags[]=cordoba & tags[]=cesar & tags[]=frontend</code>	3	on	1 candidato (ID: 265673)

**Revisión de arquitectura — Plataforma no es SSR pura**

El módulo chatEmp/ constituye la primera evidencia de comunicación asíncrona confirmada en DisJob. Dos endpoints JSON son llamados mediante fetch() desde el dashboard empresa, refutando la caracterización anterior de "sin APIs REST".

4.1 Endpoints del módulo chatEmp/**GET** /chatEmp/getNotifications.php

Polling periódico de notificaciones no leídas.
Llamado automáticamente cada ~60 segundos.

Autenticación: Cookie PHPSESSID

Content-Type respuesta: text/html ⚠

HTTP Status: 200 OK

Body:

```
{"success": true, "unread_count": "0"}
```

GET /chatEmp/getChatList.php

Carga del listado de conversaciones activas.
Devuelve HTML pre-renderizado embebido en JSON.

Autenticación: Cookie PHPSESSID

Content-Type respuesta: application/json ✓

HTTP Status: 200 OK

Body:

```
{"success": true, "html": "<ul  
id='chatList'>...</ul>"}
```

4.2 Comportamiento de polling observado

Timestamp (UTC)	Request ID	Endpoint	unread_count	Intervalo desde anterior
14:11:27.153	req_53	getNotifications.php	0	— (inicial)
14:11:27.154	req_54	getChatList.php	—	~0s (carga inicial)
14:11:27.155	req_55	getNotifications.php	0	~0s (doble carga)
14:11:38.710	req_61	getNotifications.php	0	~11s
14:12:18.717	req_62	getNotifications.php	0	~40s
14:13:38.732	req_63	getNotifications.php	0	~80s

4.3 Análisis de inconsistencias técnicas

Problema	Endpoint afectado	Esperado	Observado	Severidad
Content-Type incorrecto	getNotifications.php	application/json	text/html; charset=UTF-8	BAJA
HTML embebido en JSON	getChatList.php	Datos estructurados	Campo html con markup pre-renderizado	BAJA

Problema	Endpoint afectado	Esperado	Observado	Severidad
Polling sin WebSockets	Ambos	Push / WebSocket	HTTP polling repetido	INFO



Implicación arquitectural

El módulo chatEmp/ es probablemente una adición reciente al sistema legacy. El patrón "JSON con HTML embebido" en getChatList.php es característico de una migración incremental hacia AJAX, donde el servidor sigue renderizando HTML pero lo entrega via JSON en lugar de recargar la página. Este es el punto de entrada más natural para una modernización API-first progresiva.

5.1 Propiedades de Analytics identificadas hoy

Plataforma	ID / Propiedad	Dominio	Estado
Google Analytics UA	UA-157749752-1	empresas.disjob.com	NUEVO
Google Analytics 4	G-G51LET61C6	empresas.disjob.com	NUEVO
HubSpot (CRM)	2442099	empresas.disjob.com	NUEVO
Google Analytics UA	UA-67987350-1	www.disjob.com	Conocido
Google Analytics 4	G-DHEJSC1WDX	www.disjob.com	Conocido
Google Analytics 4	G-R3P2ZK82WP	vadempleo.disjob.com	Conocido

5.2 Integración HubSpot en portal empresa



DisJob usa HubSpot como CRM B2B

El portal empresa carga tres scripts de HubSpot en todas sus páginas (públicas y privadas). El portal candidatos no incluye HubSpot, lo que confirma que se usa exclusivamente para el segmento empresa.

Script HubSpot	Propósito inferido
<code>js.hs-analytics.net/analytics/1781100900000/2442099.js</code>	Tracking de comportamiento de visitantes empresa
<code>js-na1.hs-scripts.com/2442099.js</code>	Script principal HubSpot (tracking + CRM sync)
<code>js.hs-banner.com/v2/2442099/banner.js</code>	Banner de cookies HubSpot (alternativo al gales.js)

5.3 Nuevas librerías JavaScript identificadas

Librería	Ruta	Uso	Portales
jQuery UI 1.12.1	<code>code.jquery.com/ui/1.12.1/jquery-ui.js</code>	Componentes UI avanzados (cargado desde CDN)	Empresa
Tag-it.js	<code>/assets/js/tagit/js/tag-it.js</code>	Input de tags para el buscador de candidatos	Empresa

Librería	Ruta	Uso	Portales
app.js	<code>/assets/js/app.js?v=1.0</code>	Script personalizado principal (en ambos portales)	Ambos
touch.js	<code>/assets/plugins/image-hover/js/touch.js</code>	Soporte para eventos táctiles en hover	Ambos
style-empresa.css	<code>/assets/css/style-empresa.css</code>	CSS específico del portal empresa (en login público)	Empresa

1

NUEVO RIESGO MEDIO

Exposición datos candidatos en HTML

1

NUEVO RIESGO BAJO

IDs numéricos secuenciales

1

CONFIRMADO

X-FRAME-OPTIONS: DENY activo

6.1 Nuevos hallazgos de seguridad

Hallazgo	Evidencia	Impacto	Severidad
Exposición de datos de contacto de candidatos	El listado candidatos.php renderiza teléfono (tel:) y email (mailto:) en el HTML visible	Cualquier empresa autenticada accede directamente a datos personales sin clic adicional	MEDIA
IDs numéricos secuenciales en perfiles	perfil_candidat.php?Id=76848 — rango observado: 76848-265673	Permite enumeración de perfiles de candidatos si no hay control de autorización adicional	MEDIA-BAJA
Timestamp de acceso en URL	?data=Wed Jun 10 2026 12:14:01 GMT-0300... en URLs de perfil	Timestamp queda en logs de servidor; exposición marginal de info de horario de acceso	BAJA
Content-Type incorrecto en chat API	getNotifications.php devuelve JSON con Content-Type: text/html	Riesgo de XSS si un cliente interpreta el body como HTML en lugar de JSON	BAJA

6.2 Seguridad confirmada en esta sesión

Mecanismo	Observación	Estado
X-FRAME-OPTIONS: DENY	Declarado como meta tag HTML en todas las páginas (empresa y candidatos). Previene clickjacking.	ACTIVO
Tokens CSRF en login empresa	Campo token=829772f5e5f80ba99b7d92f43bf0234f confirmado en POST login empresa, rotado por sesión.	ACTIVO
Anti-caché post-login	?nocache=<unix_timestamp> en redirect post-login empresa (igual que en candidatos).	ACTIVO
Nueva cookie PHPSESSID por dominio	El login empresa genera una cookie PHPSESSID separada para empresas.disjob.com.	CORRECTO

Mecanismo	Observación	Estado
-----------	-------------	--------

**Campos sensibles
no en URL**

Credenciales viajan en POST, no en GET. Confirmado en login empresa.

CORRECTO

6.3 Stack confirmado (sin cambios)

PHP/5.6.38
BACKEND
EOL desde Dic 2018

nginx/1.10.3
WEB SERVER
EOL desde 2017

jQuery 1.10.2
FRONTEND LIB
CVEs activos conocidos

PHPSESSID
SESIONES
Sin HttpOnly/Secure confirmados

7.1 Conclusiones de la sesión

- **Portal empresa completamente funcional:** El área privada de empresa es significativamente más rica de lo que se intuía. Incluye flujos completos de gestión de posiciones, candidatos por oferta, killer questions y un buscador de talento exclusivo.
- **Revisión de arquitectura:** La plataforma no es SSR pura. El módulo chatEmp/ introduce AJAX con respuestas JSON, primer precedente de comunicación asíncrona en DisJob.
- **Segmentación analytics confirmada:** DisJob mantiene propiedades GA separadas para cada dominio y usa HubSpot como CRM exclusivo del segmento B2B (empresa).
- **IDs de candidatos numéricos y secuenciales:** El rango observado (76k–265k) sugiere una base de datos con más de 200.000 candidatos registrados históricamente.
- **Sesión empresa usa misma infraestructura:** PHP/5.6, nginx/1.10.3 y jQuery 1.10.2 confirmados en todas las respuestas del portal empresa, igual que en el portal candidatos.

7.2 Áreas pendientes de explorar

Área	URLs pendientes	Prioridad
Chat completo	<code>chatEmp/sendMessage.php</code> , <code>chatEmp/getMessages.php</code> (inferidos)	ALTA
Killer Questions	<code>acciones/killerquestions/alta.php</code> — formulario de creación	MEDIA
Alta de oferta	<code>ofertas_alta.php</code> — campos del formulario completo	MEDIA
Ficha empresa	<code>ficha_empresa.php</code> — campos editables de la empresa	MEDIA
Colaboradores y grupos	<code>colaboradores.php</code> , <code>grupos.php</code>	BAJA
VadEmpleo completo	Area privada de <code>vadempleo.disjob.com</code>	BAJA

7.3 Visión general de cobertura al 10/06/2026

Componente	Páginas conocidas	Formularios documentados	Cobertura estimada
Portal Candidatos (www)	~40	12	~95%
Portal Empresa — área pública	8	2	~90%
Portal Empresa — área privada	16	4	~75%
Chat empresa (chatEmp/)	2	0	~60%

Componente	Páginas conocidas	Formularios documentados	Cobertura estimada
VadEmpleo (vadempleo)	~8	1	~30%
TOTAL	90+	25+	~78% global

- ✓

La sesión del 10/06 cierra la mayor brecha de conocimiento pendiente.

El portal empresa, que representaba la mitad de la plataforma sin explorar, ha sido mapeado en sus flujos principales. El documento técnico DISJOB_TECHNICAL_AUDIT.md ha sido actualizado a la versión 1.1 con todos los hallazgos de esta sesión.